# INFORME DE PENTESTING

Evaluación de seguridad de aplicación web

*Laboratorio «DoorKick» — WHOAMI-LABS*

| | |
|---|---|
| **Objetivo** | 172.17.0.2 : 5000 (HTTP / Gunicorn) |
| **Tipo de prueba** | Caja negra — Aplicación web autenticada |
| **Resultado** | **COMPROMISO TOTAL — acceso como «admin»** |
| **Periodo** | 17 – 18 de octubre de 2026 |
| **Tiempo de compromiso** | 21 min 11 s |

**Documento confidencial**

*Elaborado con fines didácticos sobre un entorno de laboratorio autorizado.*

Autor: claude@insbaixcamp.cat

## Aviso legal y alcance

> **Autorización y entorno controlado**
>
> Todas las acciones descritas en este informe se han realizado sobre el laboratorio «DoorKick» de la plataforma WHOAMI-LABS, un entorno aislado (red 172.17.0.0/16) desplegado localmente y explícitamente autorizado para su explotación con fines de aprendizaje.
>
> No se ha atacado ningún sistema de terceros. Las técnicas aquí documentadas solo deben aplicarse sobre sistemas propios o con autorización por escrito del propietario.

El trabajo se enmarca en la **Fase 7 — Reporting** de la metodología de red team: documentar hallazgos, evidencias e impacto, y proponer remediaciones concretas. El informe reconstruye, de forma cronológica y reproducible, el camino seguido desde el descubrimiento del servicio hasta el compromiso total de la aplicación.

## Índice

# 1. Resumen ejecutivo

Se ha realizado una prueba de intrusión de caja negra contra la aplicación web **DoorKick**, expuesta en `http://172.17.0.2:5000`. Partiendo únicamente de la dirección IP, se logró el **compromiso completo del panel de administración** en apenas 21 minutos.

El vector decisivo fue un **ataque de fuerza bruta sobre el formulario de inicio de sesión**, facilitado por tres debilidades que se refuerzan entre sí: un nombre de usuario conocido y revelado por la propia aplicación (`admin`), la ausencia total de mecanismos de bloqueo o limitación de intentos (*rate-limiting*), y el uso de una contraseña débil y presente en diccionarios públicos (`welcome1`).

Como consecuencia, un atacante obtiene acceso con privilegios de administrador a la aplicación, lo que en un entorno real supondría el control sobre todos los datos y funciones gestionados por ella.

## 1.1. Valoración global del riesgo

Nivel de riesgo general: **CRÍTICO**

La combinación de usuario predecible, falta de protección contra fuerza bruta y contraseña trivial permite un acceso no autorizado fiable y repetible, sin requerir conocimientos avanzados ni herramientas sofisticadas.

## 1.2. Hallazgos principales

| # | Hallazgo | Severidad | Estado |
|---|---|---|---|
| H-01 | Fuerza bruta en el login sin rate-limiting → acceso admin | CRÍTICO | Confirmado |
| H-02 | Enumeración de usuario válido («admin» divulgado) | ALTO | Confirmado |
| H-03 | Contraseña débil / de diccionario («welcome1») | ALTO | Confirmado |
| H-04 | Nonce predecible e incremental en /api/nonce y /token | MEDIO | Confirmado |
| H-05 | Ausencia de token Anti-CSRF en formularios | MEDIO | Confirmado |
| H-06 | Cabeceras de seguridad ausentes (CSP, X-Content-Type, X-Frame) | BAJO | Confirmado |
| H-07 | Exposición a Slowloris / DoS (CVE-2007-6750) | BAJO | Probable |

# 2. Metodología y alcance

El ejercicio sigue las fases habituales de una operación ofensiva, alineadas con el marco **MITRE ATT&CK** y con la ruta de aprendizaje del laboratorio. Las fases cubiertas en esta prueba fueron:

| Fase | Objetivo | Herramientas empleadas |
|---|---|---|
| 2 — Reconocimiento y enumeración | Descubrir el servicio, rutas y parámetros | Nmap, Gobuster, Feroxbuster, DevTools |
| 3 — Acceso inicial | Obtener credenciales válidas | OWASP ZAP (Fuzzer), diccionario |
| 7 — Reporting | Documentar hallazgos e impacto | Este informe |

## 2.1. Alcance (scope)

- **Host autorizado:** `172.17.0.2` (único objetivo).
- **Servicio:** aplicación web DoorKick sobre el puerto `5000/tcp` (Gunicorn).
- **Fuera de alcance:** cualquier otro host de la red y toda infraestructura ajena al laboratorio.

## 2.2. Entorno del atacante

Las pruebas se ejecutaron desde una máquina **Kali Linux** situada en la misma red aislada que el objetivo, usando la cadena de herramientas estándar del sector para reconocimiento y ataque web.

# 3. Desarrollo del ataque y evidencias

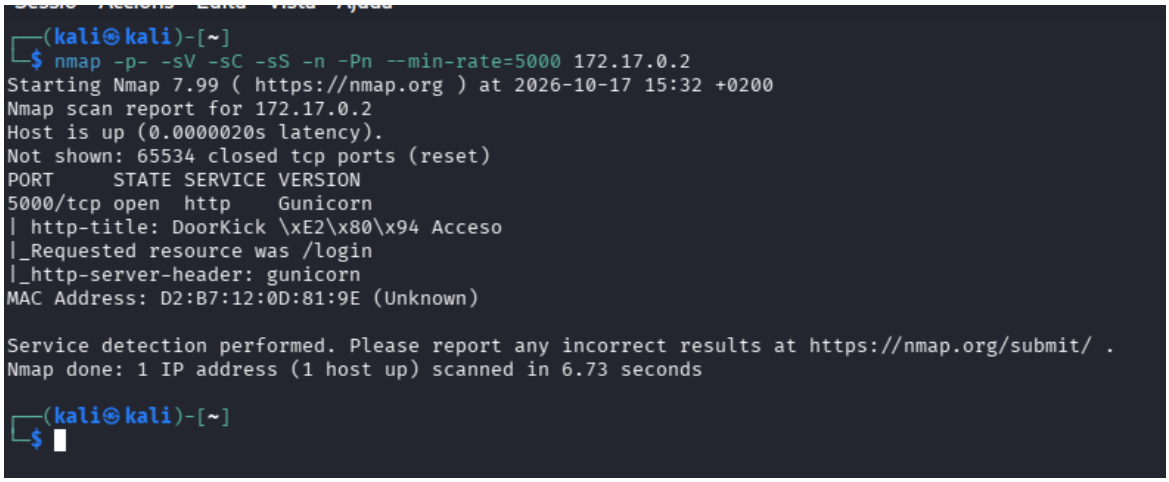
Esta sección reconstruye, paso a paso y en orden cronológico, las acciones realizadas. Cada paso se acompaña de la captura de pantalla correspondiente como evidencia.

## 3.1. Descubrimiento de servicios (Nmap)

Se lanzó un barrido completo de puertos con detección de versión y scripts por defecto:

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

De los 65.535 puertos, solo **5000/tcp** aparece abierto, sirviendo HTTP mediante `Gunicorn`. El título de la página («DoorKick — Acceso») y la redirección a `/login` confirman que se trata de un panel de autenticación. Esto reduce toda la superficie de ataque a una única aplicación web.




*Evidencia 1 — Nmap: único puerto abierto 5000/tcp (HTTP / Gunicorn), recurso /login.*

## 3.2. Análisis de vulnerabilidades conocidas (Nmap --script=vuln)

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2 --script=vuln
```

Los scripts de vulnerabilidades reportan el servidor como **probablemente vulnerable a Slowloris** (`CVE-2007-6750`, denegación de servicio) y señalan posibles problemas de CSRF en los formularios de `/login`. No se detectó XSS almacenado ni basado en DOM.

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2 --script=vuln
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-17 15:33 +0200
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65534 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
5000/tcp open  http    Gunicorn
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2007-6750
|       Slowloris tries to keep many connections to the target web server open and hold
|       them open as long as possible.  It accomplishes this by opening connections to
|       the target web server and sending a partial request. By doing so, it starves
|       the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       http://ha.ckers.org/slowloris/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=172.17.0.2
|   Found the following possible CSRF vulnerabilities:
|
|     Path: http://172.17.0.2:5000/
|     Form id:
|     Form action: /login
|
|     Path: http://172.17.0.2:5000/login
|     Form id:
|_    Form action: /login
|_http-server-header: gunicorn
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
MAC Address: D2:B7:12:0D:81:9E (Unknown)

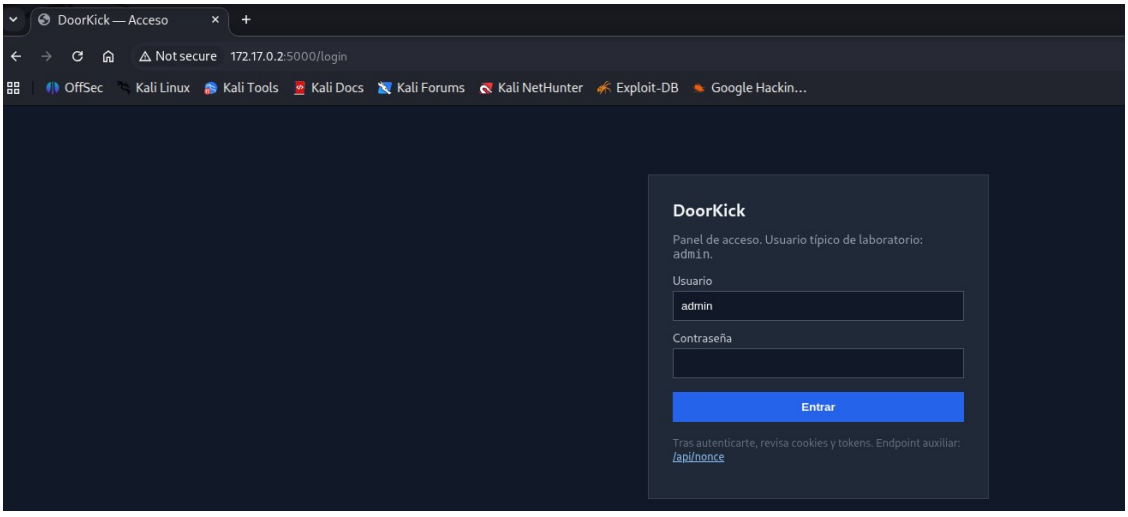
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 86.45 seconds

┌──(kali㉿kali)-[~]
└─$
```

*Evidencia 2 — Nmap --script=vuln: Slowloris (CVE-2007-6750) y formularios sin protección CSRF.*

## 3.3. Reconocimiento de la aplicación

Al visitar `http://172.17.0.2:5000/login` se observa el panel DoorKick. La propia página **divulga información sensible**: indica que el «usuario típico de laboratorio» es `admin` y expone un endpoint auxiliar `/api/nonce`. Esta pista elimina la necesidad de enumerar usuarios y reduce el ataque a adivinar únicamente la contraseña.

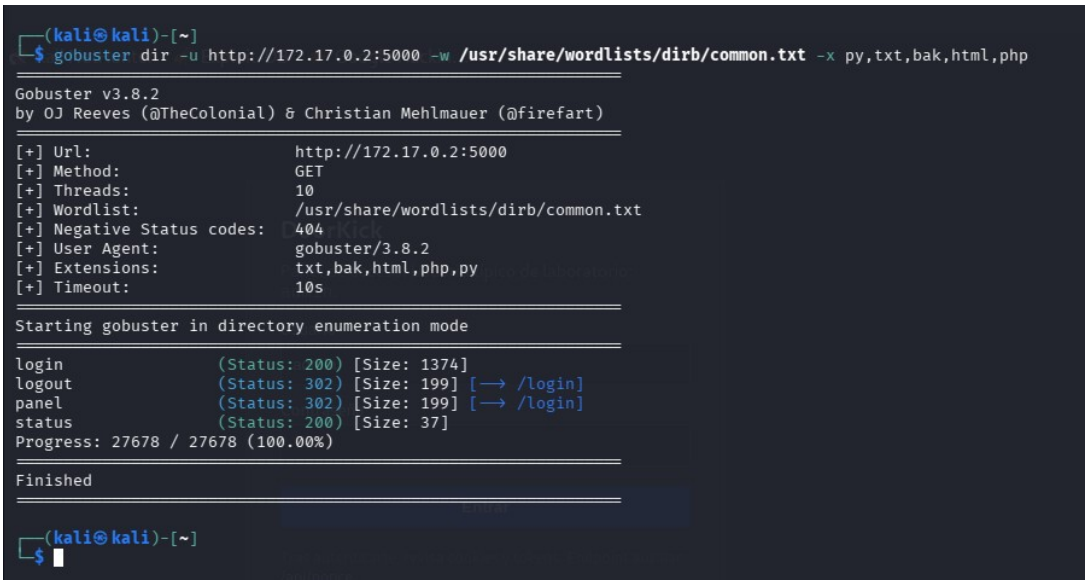



*Evidencia 3 — Panel de acceso DoorKick: se revela el usuario «admin» y el endpoint /api/nonce.*

## 3.4. Enumeración de directorios (Gobuster)

```
gobuster dir -u http://172.17.0.2:5000 \
  -w /usr/share/wordlists/dirb/common.txt -x py,txt,bak,html,php
```

Gobuster descubre las rutas `/login`, `/logout`, `/panel` (redirige a login si no hay sesión) y `/status`. El endpoint `/panel` es el objetivo final: el área protegida tras la autenticación.




*Evidencia 4 — Gobuster: rutas login, logout, panel y status.*

## 3.5. Enumeración recursiva (Feroxbuster)

```
feroxbuster -u http://172.17.0.2:5000 -t 5 -x php,bak,txt,html,py,zip \
  -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

Una segunda pasada con un diccionario más amplio confirma lo anterior y añade dos endpoints de API de interés: `/api/nonce` y `/token`, ambos con respuesta `200 OK`.




*Evidencia 5 — Feroxbuster: confirmación de rutas y descubrimiento de /api/nonce y /token.*

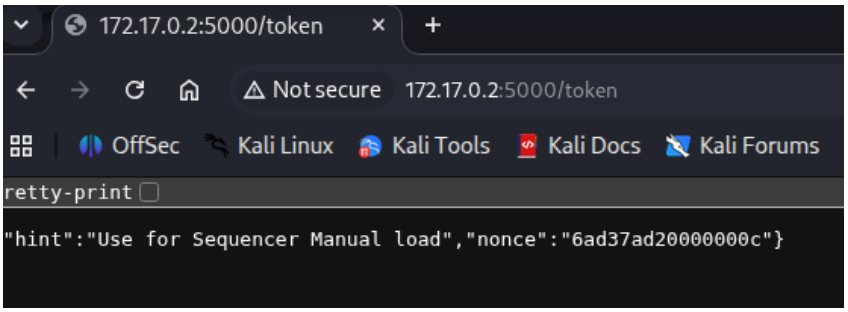
## 3.6. Inspección de los endpoints de API

Al consultar `/token` y `/api/nonce` se observan respuestas JSON con una pista («Use for Sequencer Manual load») y un valor `nonce`:

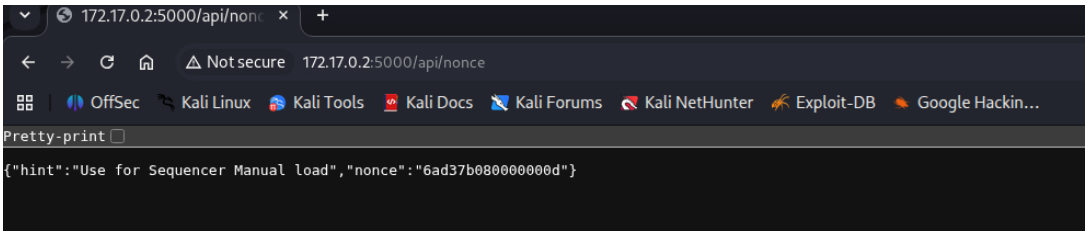
| Endpoint | Respuesta observada |
|---|---|
| /token | `{"hint":"Use for Sequencer Manual load","nonce":"6ad37ad20000000c"}` |
| /api/nonce | `{"hint":"Use for Sequencer Manual` |

| Endpoint | Respuesta observada |
|---|---|
| | `load","nonce":"6ad37b080000000d"}` |

Comparando ambos valores (`...0c` y `...0d`) se aprecia que el nonce es **secuencial y predecible**: se incrementa de forma determinista entre peticiones. Un nonce debería ser impredecible; su previsibilidad debilita cualquier mecanismo que dependa de él (por ejemplo, protección anti-repetición).



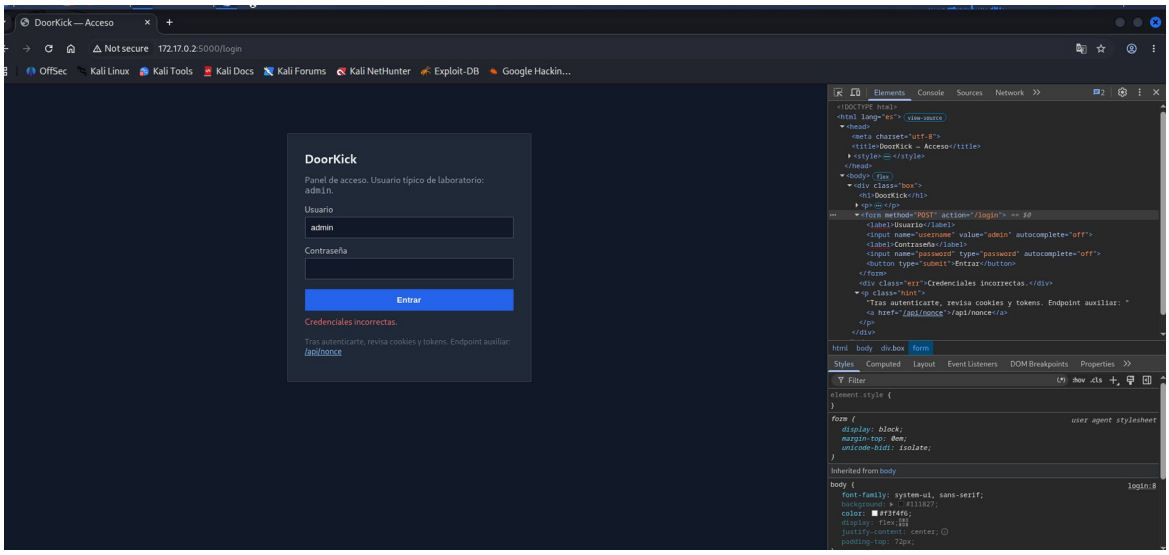

*Evidencia 6 — /token: nonce 6ad37ad20000000c.*




*Evidencia 7 — /api/nonce: nonce 6ad37b080000000d (valor incrementado → predecible).*

## 3.7. Análisis del formulario de login (DevTools)

La inspección del DOM confirma la estructura del formulario: método `POST` hacia `/login`, con los campos `username` (prerrelleno con `admin`) y `password`. Con esto queda definida la petición a automatizar para el ataque de fuerza bruta.



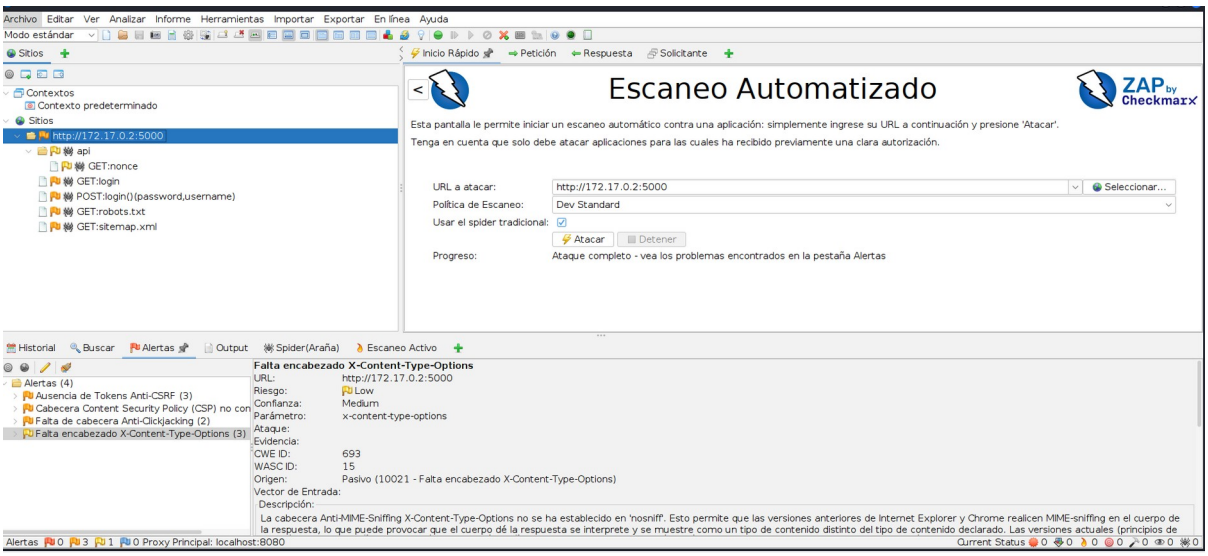

*Evidencia 8 — DevTools: form POST /login con campos username=admin y password.*

## 3.8. Escaneo pasivo (OWASP ZAP)

Se procesó la aplicación con OWASP ZAP. El análisis pasivo generó varias alertas de configuración que, sin ser críticas por sí solas, reflejan una postura de seguridad deficiente:

- **Ausencia de tokens Anti-CSRF** en los formularios (3 instancias).

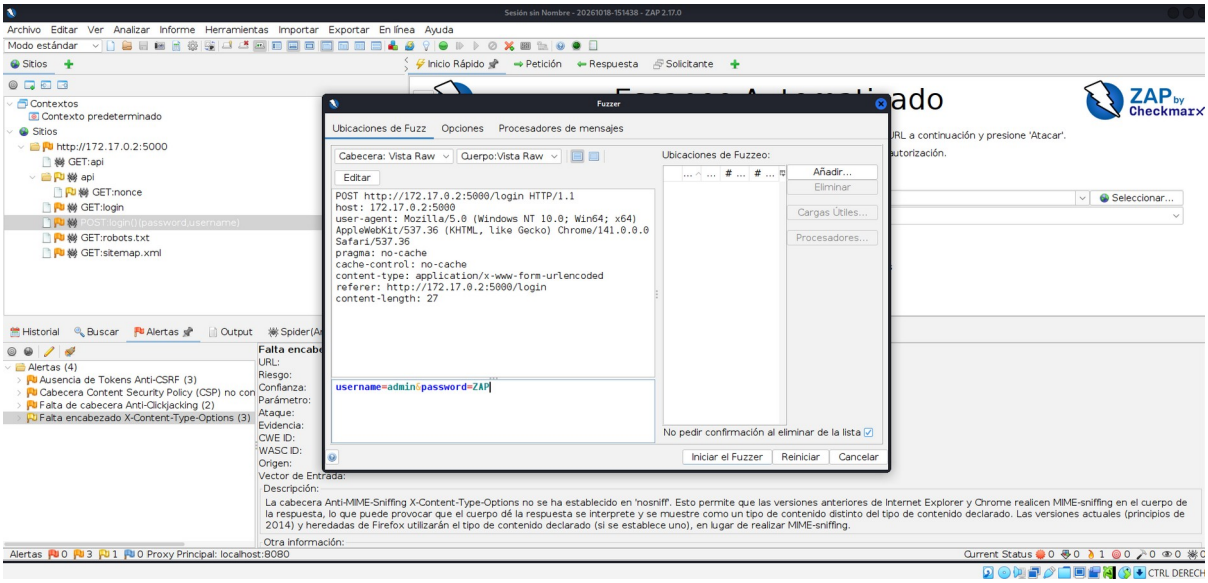
- **Cabecera Content-Security-Policy (CSP) no configurada**.
- **Falta de cabecera Anti-Clickjacking** (X-Frame-Options, 2 instancias).
- **Falta de X-Content-Type-Options: nosniff** (3 instancias, CWE-693).




*Evidencia 9 — OWASP ZAP: alertas de cabeceras de seguridad ausentes y falta de Anti-CSRF.*

## 3.9. Preparación del ataque de fuerza bruta (ZAP Fuzzer)

Se interceptó la petición `POST /login` con cuerpo `username=admin&password=ZAP`. El marcador ZAP define la posición de fuzzing: ZAP sustituye ese valor por cada entrada de un diccionario de contraseñas, dejando el usuario fijo en `admin`.

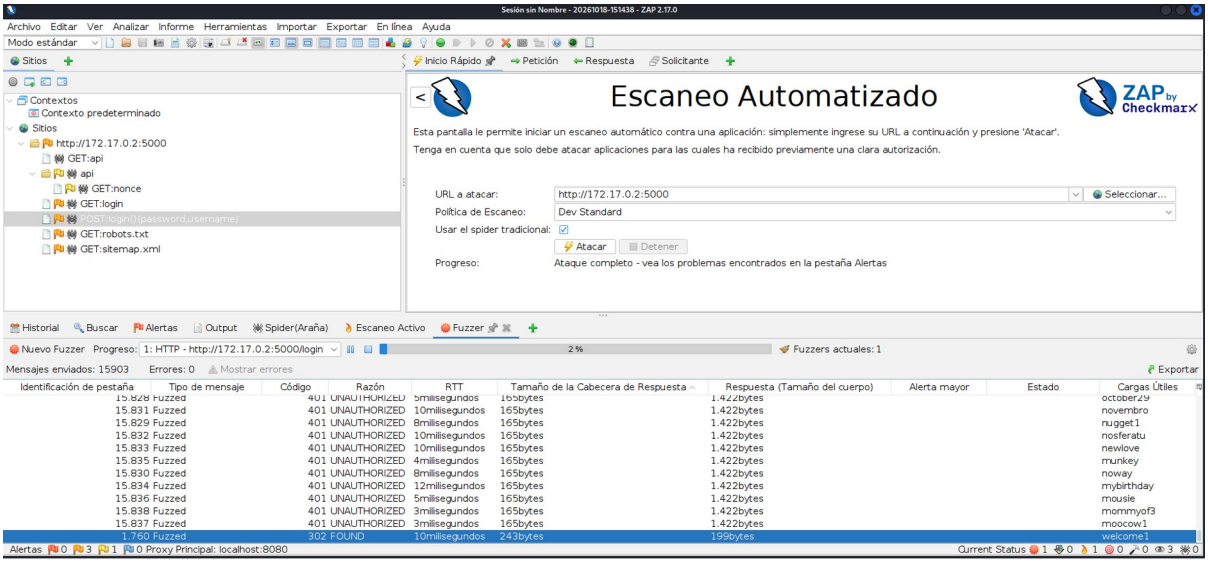



*Evidencia 10 — ZAP Fuzzer: posición de fuzzing sobre el parámetro password (usuario admin fijo).*

## 3.10. Ejecución y hallazgo de la credencial

Durante la ejecución se enviaron **más de 15.900 peticiones** sin que la aplicación impusiera ningún bloqueo ni retardo — confirmación directa de la **ausencia de rate-limiting**. La inmensa mayoría devolvió `401 Unauthorized` con un cuerpo de tamaño constante (1.422 bytes).

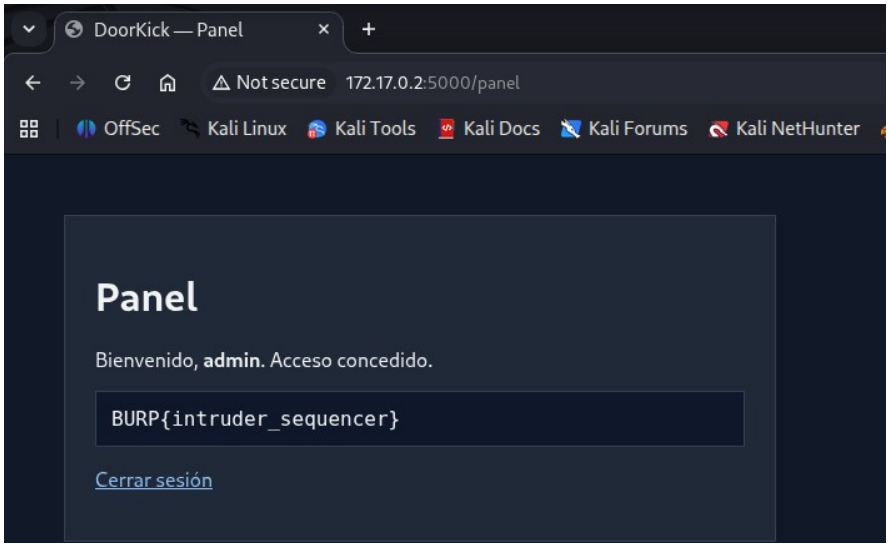
La carga útil `welcome1` se distingue del resto: devuelve `302 FOUND` y un cuerpo de tamaño distinto (199 bytes), señal inequívoca de una **autenticación exitosa** con redirección al panel.



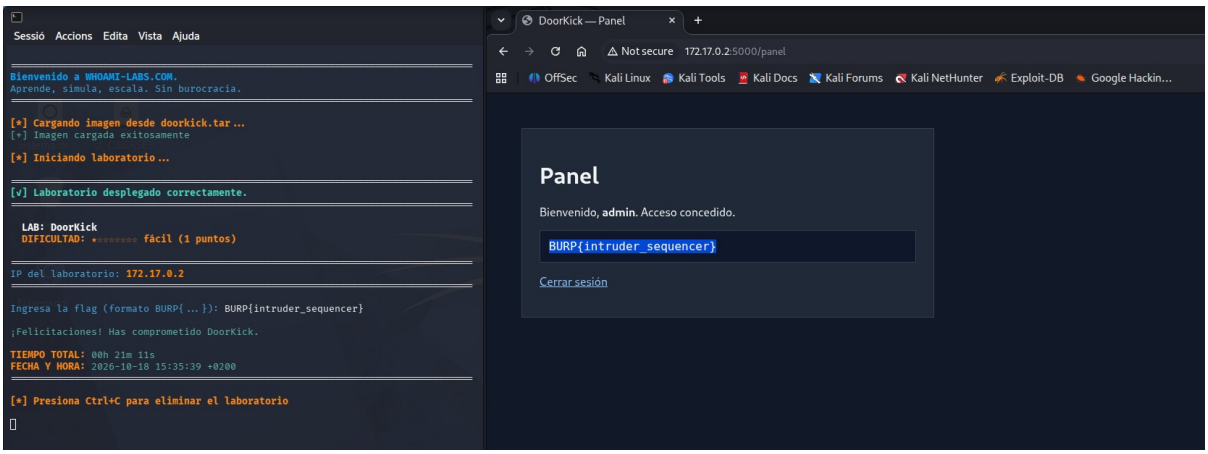

*Evidencia 11 — ZAP Fuzzer: «welcome1» responde 302 FOUND (tamaño distinto) frente a los 401 del resto → credencial válida.*

## 3.11. Acceso al panel y captura de la flag

Autenticándose con `admin : welcome1` se accede al panel de administración, que muestra «Bienvenido, admin. Acceso concedido» y revela la flag del laboratorio `BURP{intruder_sequencer}`. Esto certifica el compromiso total de la aplicación.




*Evidencia 12 — Panel de administración con acceso concedido y flag BURP{intruder_sequencer}.*




*Evidencia 13 — Validación de la flag en WHOAMI-LABS: «¡Has comprometido DoorKick!» — tiempo total 00h 21m 11s.*

# 4. Hallazgos detallados y remediación

A continuación se detalla cada hallazgo con su impacto y las medidas correctoras recomendadas para el equipo técnico.

## H-01 — Fuerza bruta sin limitación de intentos (rate-limiting)

Severidad: **CRÍTICO**

El endpoint `POST /login` acepta un número ilimitado de intentos de autenticación sin bloqueo de cuenta, retardo progresivo, CAPTCHA ni límite por IP. Se enviaron más de 15.900 peticiones sin interferencia alguna (evidencia 11).

**Impacto:** Permite adivinar contraseñas de forma automatizada y fiable. Es la causa raíz que convierte las contraseñas débiles en un compromiso real.

**Remediación:**

- Implementar rate-limiting por IP y por cuenta (p. ej. máximo 5 intentos / 15 min).
- Bloqueo temporal o exponencial tras intentos fallidos consecutivos.
- Añadir CAPTCHA tras varios fallos y alertar ante picos de 401.
- Habilitar autenticación multifactor (MFA) en el panel de administración.

## H-02 — Divulgación de nombre de usuario válido

Severidad: **ALTO**

La página de login indica explícitamente que el usuario es `admin` y lo prerrellena en el formulario (evidencias 3 y 8). Esto elimina la mitad del esfuerzo de un ataque de fuerza bruta.

**Impacto:** Reduce el espacio de búsqueda del atacante al solo tener que adivinar la contraseña, aumentando drásticamente la probabilidad de éxito.

**Remediación:**

- No revelar nombres de usuario en la interfaz ni en mensajes de error.
- Usar mensajes de error genéricos («usuario o contraseña incorrectos»).
- Evitar cuentas por defecto predecibles como «admin».

## H-03 — Contraseña débil / presente en diccionarios

Severidad: **ALTO**

La contraseña de la cuenta administradora era `welcome1`, una de las más comunes en listas públicas de contraseñas filtradas. Fue descubierta por diccionario en minutos.

**Impacto:** Una contraseña de este tipo se adivina casi de inmediato en cuanto existe fuerza bruta, dando acceso administrativo completo.

**Remediación:**

- Exigir una política de contraseñas robusta (longitud, complejidad).
- Contrastar las contraseñas contra listas de filtraciones conocidas (p. ej. HaveIBeenPwned).
- Forzar el cambio de credenciales por defecto en el primer uso.

## H-04 — Nonce predecible e incremental

Severidad: **MEDIO**

Los endpoints `/token` y `/api/nonce` devuelven valores de nonce secuenciales (`...0c` → `...0d`), por lo que son predecibles (evidencias 6 y 7).

**Impacto:** Un nonce predecible puede permitir ataques de repetición o la falsificación de peticiones que dependan de dicho valor como medida de seguridad.

**Remediación:**

- Generar nonces con un generador criptográficamente seguro (CSPRNG).
- Asociar cada nonce a una sesión y a una caducidad corta, invalidándolo tras su uso.

## H-05 — Ausencia de protección Anti-CSRF

Severidad: MEDIO

Tanto Nmap como OWASP ZAP detectaron formularios sin token Anti-CSRF (evidencias 2 y 9).

**Impacto:** Permite que un sitio malicioso induzca acciones no deseadas en nombre de un usuario autenticado.

**Remediación:**

- Incorporar tokens Anti-CSRF únicos por sesión en todos los formularios que modifiquen estado.
- Aplicar el atributo SameSite a las cookies de sesión.

## H-06 — Cabeceras de seguridad HTTP ausentes

Severidad: BAJO

Faltan `Content-Security-Policy`, `X-Frame-Options` y `X-Content-Type-Options: nosniff` (evidencia 9, CWE-693).

**Impacto:** Facilita ataques de clickjacking, MIME-sniffing e inyección de contenido en navegadores antiguos.

**Remediación:**

- Configurar una CSP restrictiva.
- Añadir X-Frame-Options: DENY (o frame-ancestors en la CSP) y X-Content-Type-Options: nosniff.

## H-07 — Exposición a denegación de servicio (Slowloris)

Severidad: BAJO

Nmap marca el servidor como probablemente vulnerable a Slowloris (`CVE-2007-6750`, evidencia 2).

**Impacto:** Un atacante podría agotar las conexiones del servidor y provocar una denegación de servicio con pocos recursos.

**Remediación:**

- Situar un proxy inverso / WAF (nginx) delante de Gunicorn con límites de conexión y timeouts.
- Ajustar los timeouts y el número de workers de Gunicorn.

# 5. Conclusiones

El laboratorio DoorKick se comprometió por completo en **21 minutos y 11 segundos**, obteniendo acceso administrativo a través de una cadena simple pero efectiva: **usuario conocido + sin rate-limiting + contraseña de diccionario**. Ninguna de las tres debilidades es, por sí sola, extraordinaria; es su combinación la que resulta crítica.

La prioridad de remediación es clara: implantar limitación de intentos y MFA en el login (H-01), y erradicar las credenciales débiles y por defecto (H-02, H-03). Estas medidas, de bajo coste, rompen la cadena de ataque en su eslabón principal. El resto de hallazgos (nonce predecible, CSRF, cabeceras y DoS) deben corregirse para reforzar la postura general de seguridad.

En términos de aprendizaje, el ejercicio cubre de forma completa las fases de **reconocimiento, enumeración y acceso inicial**, y culmina con la fase de reporting que da sentido profesional a todo el trabajo previo.

## 5.1. Resumen de prioridades

| Prioridad | Acción | Hallazgos |
|---|---|---|
| 1 | Rate-limiting + MFA en el login | H-01 |
| 2 | Eliminar usuario/contraseña por defecto y débiles | H-02, H-03 |
| 3 | Nonce seguro y tokens Anti-CSRF | H-04, H-05 |
| 4 | Cabeceras de seguridad y mitigación DoS | H-06, H-07 |

*— Fin del informe —*